

BEFORE Placeholder

AFTER

API Integration Control Baseline (Read/Write, Tiered)

Document classification: Internal

Baseline owner: Security Engineering/Architecture

Version: 0.1

Effective date: _____

Review cadence: Annually

1. Purpose

Define minimum controls for third-party API integrations to ensure least privilege, secure credential handling, auditability, and controlled change management—especially where integrations can write to systems or influence production.

2. Scope

Applies to any integration where:

- a supplier calls organisational APIs, or
- the organisation calls supplier APIs, or
- an iPaaS/automation platform is used, and where data or actions are performed via API.

3. Risk model (what this baseline protects against)

- Over-permissioned API scopes enabling data exfiltration or destructive changes
- Token/key compromise leading to persistent unauthorised access
- Undetected write actions and integrity compromise

- Uncontrolled scope creep (read → write, broader datasets)
- Weak separation between prod/non-prod and read/write identities

4. Control statements (tiered)

4.1 Tier Critical (Tier 1) — MUST controls

Critical API integrations MUST:

1. Use **dedicated non-human identities** (app registration/service account) for the integration (no personal accounts).
2. Enforce **environment separation**:
 - separate identities for production vs non-production.
3. Enforce **least privilege**:
 - permissions/scopes mapped to required endpoints/objects
 - write permissions only when explicitly justified
4. Enforce **read vs write separation**:
 - separate identities for read-only and write integrations where write is required.
5. Secure credential handling:
 - secrets stored in approved secrets store (vault/secure store)
 - no secrets in code, tickets, or plain configuration files
6. Credential lifecycle:
 - rotation defined with an owner and schedule
 - immediate revoke/rotate on suspected compromise and on offboarding
7. Auditability:
 - authentication events, permission changes, and API activity (esp. writes) logged and retrievable
8. Change control:
 - scope/permission changes are ticketed, reviewed, and approved prior to implementation

Critical API integrations SHOULD:

- use short-lived tokens/OAuth flows over static API keys where supported
- restrict calls via allowlisted egress IPs/private endpoints where supported
- implement alerting for anomalous call volumes and write actions (supplier or customer-side)

4.2 Tier Important (Tier 2) — MUST controls

Important API integrations MUST:

- use dedicated integration identity
- apply least privilege scopes and document mapping
- store secrets securely and define rotation approach
- ensure API activity is auditable to the extent the platform supports it
- apply change control for permission/scope changes

Important API integrations SHOULD:

- separate prod/non-prod identities (recommended)
- separate read/write identities where practical

4.3 Tier Low (Tier 3) — proportionate controls

Low API integrations SHOULD:

- use dedicated integration identity
- avoid write access where possible
- store credentials securely
- log/retrieve integration activity where supported

5. Baseline requirements by control area

5.1 Identity and ownership

MUST:

- Each integration has:
 - a named Business Service Owner
 - an IT/Platform Owner
 - a Security reviewer (SEA)
- Integration identity is uniquely attributable to the integration purpose.

5.2 Permissions and scope management

MUST:

- Create an "API scope map" documenting:
 - endpoints/objects accessed
 - required scopes/roles
 - data types accessed
 - read vs write operations
- For write access:
 - justify why write is needed
 - limit write to specific objects/actions
 - implement safeguards (approval gates/workflow constraints) where possible

SHOULD:

- Use separate micro-identities per function (e.g., reporting vs provisioning) to reduce blast radius.

5.3 Credential storage and handling

MUST:

- Store secrets in approved vault/secure store with access restrictions.
- Prohibit sharing secrets via email/chat/tickets.
- Document emergency revoke steps and owner.

SHOULD:

- Use automated rotation where supported.

5.4 Rotation and revocation

MUST:

- Rotation schedule documented by tier:
 - Tier Critical: rotation schedule defined (e.g., 90–180 days) or per internal standard
 - Tier Important: rotation schedule defined
- Revoke/rotate immediately on:
 - suspected compromise
 - admin role change affecting secret access
 - supplier offboarding/termination

5.5 Network restrictions (where supported)

MUST (if feasible/supported):

- Restrict source IPs/egress where the platform supports allowlisting.
- Avoid inbound callbacks/webhooks unless required and approved.

SHOULD:

- Use private endpoints/private connectivity for high-risk Critical integrations where available and justified.

5.6 Logging, monitoring, and alerting

MUST:

- Ensure logs exist for:
 - integration identity authentication/token events (where available)
 - admin changes to scopes/roles

- API calls relevant to the integration; write actions specifically
- Retain and retrieve logs per Logging baseline.

SHOULD:

- Alert on:
 - permission changes
 - unusual volumes
 - write actions outside expected windows
 - repeated auth failures

5.7 Change control

MUST:

- Scope changes require:
 - change request with rationale
 - security review and approval
 - validation evidence post-change
- Re-triage required if:
 - read becomes write
 - new sensitive data types introduced
 - new systems added
 - privileges expand materially

6. Validation steps (how to prove it)

For each integration, record evidence location and complete checks.

6.1 Identity checks

- ☐ Dedicated integration identity created (non-human)
- ☐ Prod/non-prod separation implemented (Critical required)
- ☐ Read/write separation implemented where write exists (Critical required)

Evidence location:

6.2 Scope/permission checks

- ☐ API scope map completed (endpoints/objects → scopes/roles)
- ☐ Least privilege confirmed by review
- ☐ Write access justified and constrained (if applicable)

Evidence location:

6.3 Secrets handling checks

- ☐ Secrets stored in approved vault/secure store
- ☐ Access to secrets restricted to named roles
- ☐ Rotation owner and schedule defined

Evidence location:

6.4 Rotation/revocation checks

- ☐ Rotation procedure documented and testable
- ☐ Emergency revoke steps documented

Evidence location:

6.5 Logging checks

- ☐ Authentication/token events captured (where available)
- ☐ Scope/role changes logged
- ☐ API activity logged; write actions attributable (if applicable)
- ☐ Retrieval/export method tested

Evidence location:

6.6 Change control checks

- ☐ Change process defined for scope changes
- ☐ Last change (if any) has ticket, approval, and validation evidence

Evidence location:

7. Exceptions

Any deviation from Tier Critical MUST requirements requires a policy exception with:

- compensating controls (e.g., scope reduction, additional monitoring, reduced exposure windows)
- expiry date and remediation plan.

8. Sign-off (per integration)

Integration name: _____ Supplier: _____ Tier: ☐ Critical ☐ Important ☐ Low

Security Engineering/Architecture (role title): _____ Date: _____ IT/Platform Owner (role title): _____ Date: _____ Business Service Owner (role title): _____ Date: _____ DPO/Privacy Officer (if personal data): _____ Date: _____